

Relazione di Threat Modeling: Simulazione di Attacco Spear-Phishing

PRE-INTRODUZIONE

Il lavoro si propone di analizzare e mappare la superficie di attacco esposta da una figura di alto profilo nel panorama sportivo internazionale: Marcelo Méndez, Direttore della Comunicazione della holding che gestisce gli interessi globali di Lionel Messi.

La scelta di focalizzare l'analisi su questo specifico target non è casuale, ma nasce dalla consapevolezza che, durante eventi di portata mondiale come i Mondiali di calcio, l'attenzione mediatica e il volume di traffico informativo raggiungono picchi tali da creare un terreno fertile per attività di cyber-spionaggio e frodi finanziarie. La figura di Messi, dotata di un ecosistema digitale capillare — che comprende non solo il suo sito web ufficiale, ma anche una complessa rete di sponsorizzazioni, diritti d'immagine e comunicazioni logistiche — rende la sua holding un bersaglio primario per minacce informatiche.

L'analisi è partita dallo studio del perimetro digitale del team di gestione, identificando in Marcelo Méndez il punto di contatto nevralgico: come Direttore della Comunicazione, egli è costantemente coinvolto in scambi di dati sensibili, approvazioni di contratti e gestione di crisi.

Attraverso l'utilizzo di strumenti di Open Source Intelligence (OSINT) e la modellazione grafica tramite Maltego, ho proceduto a ricostruire una possibile catena di attacco basata su una campagna di phishing mirato (*spear-phishing*). Il processo si è articolato nei seguenti passaggi:

1. Reconnaissance: Identificazione dei canali di comunicazione del target e della holding.
2. Preparazione: Creazione di un'infrastruttura di attacco simulata, includendo la registrazione di un dominio (*typosquatting*) camuffato per apparire istituzionale.
3. Vettorizzazione: Definizione della leva psicologica — basata sui postulati di Cialdini (Autorità e Urgenza) — finalizzata a indurre il target a interagire con un portale di phishing.
4. Mitigazione: Mappatura dei necessari controlli difensivi (DMARC/SPF/DKIM e autenticazione forte FIDO2) per neutralizzare il rischio.

Introduzione

Si svolge un attacco contro Lionel Messi tramite Marcelo Mendez (capo della comunicazione e della holding di Messi) attraverso la sua email, verrà inviato un messaggio con nome "Bank of America" (sponsor di Messi). L'e-mail viene inviata sfruttando l'autorità di Bank of America. Il contenuto è progettato per colpire la responsabilità professionale di Marcelo Méndez in quanto Direttore della Comunicazione della holding. Il messaggio simula una comunicazione urgente relativa alla conformità dei diritti d'immagine necessari per le attività di sponsorizzazione legate ai Quarti di Finale del torneo 2026, minacciando il blocco immediato dei fondi pubblicitari e delle autorizzazioni d'uso del marchio in caso di mancata risposta entro 24 ore.

1. Fase 1: Ricerca OSINT e Metodologia di Analisi

Per mappare la superficie di attacco, è stata condotta un'attività di ricerca OSINT mirata, esaminando documenti pubblici e rassegne stampa per ricostruire il contesto operativo e le vulnerabilità dell'obiettivo. Le fonti documentali analizzate includono file pdf ottenuti con una ricerca avanzata tramite **Google Dorking** per circoscrivere l'infrastruttura digitale e le informazioni sensibili, utilizzando i seguenti parametri:

- **Query di Ricerca:** Sono stati utilizzati operatori avanzati come `after:2026-06-01` per filtrare gli eventi recenti, `filetype:pdf` per isolare documenti ufficiali e stringhe di ricerca combinate come `"Lionel messi" OR "argentina"`.

L'analisi di tali documenti ha permesso di mappare le scadenze legali, la struttura contrattuale e gli spostamenti logistici dello staff dell'atleta. La restante parte dell'analisi è stata svolta con l'uso di AI per scoprire nomi e ruoli dello staff medico e della squadra. Essendo impegnato ai mondiali la sua routine è limitata e la sua cerchia si limita a queste persone.

Analisi Documentale: L'analisi dei PDF reperiti ha permesso di mappare scadenze legali, clausole contrattuali e spostamenti logistici dello staff dell'atleta. Tra le fonti analizzate ne allego le prime 3:

- <https://www.gulf-times.com/pdf/2026/06/11/sport-20260611-1.pdf?ts=004958>: usato per tracciare la cronologia degli eventi sportivi, comprendere il clima di attesa intorno ai match e identificare le dinamiche dei media partner, elementi essenziali per rendere il pretesto dell'attacco (legato alla visibilità del brand) coerente con quanto riportato dalla stampa di settore in quel periodo.
- [https://www.drishtiias.com/images/pdf/6.%20Consolidation%20June%20\(Uttar%20Pradesh\)%202026.pdf](https://www.drishtiias.com/images/pdf/6.%20Consolidation%20June%20(Uttar%20Pradesh)%202026.pdf): L'analisi di questo materiale ha permesso di calibrare il tono di voce dell'e-mail di phishing, rendendola simile a una comunicazione ufficiale di *compliance* o di verifica amministrativa, aumentando così la probabilità che il target la consideri legittima.
- <https://dailypioneer.com/uploads/2026/epaper/july/delhi-english-edition-2026-07-02.pdf>: Analizzando questa edizione, si è potuto estrapolare informazioni aggiornate sulla logistica dell'evento e sugli spostamenti previsti, permettendo di lanciare l'attacco proprio quando il Direttore della Comunicazione era sotto massima pressione operativa e, di conseguenza, più propenso a commettere errori di valutazione.
- Le restanti fonti utilizzate mi hanno permesso di perfezionare la credibilità dell'attacco come studiare i pattern visivi e la struttura delle notifiche informative, garantendo che l'aspetto grafico e formale dell'e-mail fosse ineccepibile; oppure il rigore lessicale e il framework legale necessario per rendere la minaccia di 'congelamento del budget' tecnicamente allineata agli accordi contrattuali reali del settore.

Identificazione del Target: Per l'individuazione dell'indirizzo e-mail di **Marcelo Méndez**, è stato utilizzato il portale **Rocketreach.com**, strumento di intelligence aziendale che ha fornito i dati necessari alla finalizzazione del contatto.

Fase 2 e 3: Progettazione e Generazione dell'Esca

Si è proceduto alla creazione di un'e-mail di *Whaling* mirata, progettata per sfruttare l'autorità di Bank of America e la leva psicologica dell'urgenza.

Il Testo dell'E-mail Simulato

Da: Bank of America - Global Sports Marketing Compliance <compliance@marketing-bankofamerica-portal.com>

A: marcelo@uniquefc.net

Oggetto: URGENTE: Verifica Conformità Diritti d'Immagine "Lionel Messi" - Quarti di Finale 2026 (Richiesta Sblocco Budget #BOFA-99382)

Alla cortese attenzione di: Marcelo Méndez

Direttore della Comunicazione e Gestione Brand – Lionel Messi Operations

Gentile Dott. Méndez,

In qualità di Main Sponsor ufficiale, il dipartimento *Global Sports Marketing & Brand Compliance* di Bank of America effettua monitoraggi costanti sulle campagne pubblicitarie. A seguito di un controllo automatizzato sui flussi di clearing legati al brand "**Lionel Messi**", è emersa una mancata corrispondenza nei moduli KYC. Risulta assente la firma digitale sul documento di manleva per il match dei Quarti di Finale di domenica 12 luglio.

IMPORTANTE: La mancata regolarizzazione comporta il congelamento dell'erogazione del budget pubblicitario. La invitiamo a controfirmare entro le prossime **24 ore**.

 **Accedi al Portale Commercial Banking - Verifica Brand BoFA**

Certi della collaborazione, restiamo a disposizione.

Dipartimento Brand Compliance & Sports Operations

Analisi del Flusso di Lavoro (Scenario di Phishing): In un contesto di alta pressione, come quello dei Quarti di Finale dei Mondiali, la velocità è tutto. Spesso, nei processi di "manleva" o di autorizzazione rapida tra la holding e partner esterni, si tende a saltare passaggi burocratici formali per non bloccare operazioni logistiche. La mancanza di firma digitale è il punto classico che un attaccante cerca di sfruttare o che un analista di sicurezza segnalerebbe come vulnerabilità critica.

Fase 4: Debriefing e Analisi Critica

La validazione dell'operazione di *Spear-Phishing* condotta contro **Marcelo Méndez** evidenzia un equilibrio critico tra l'efficacia del pretesto sociale e la fragilità dell'infrastruttura di attacco.

1. Analisi della Credibilità e del Contesto

La comunicazione è stata strutturata per risultare autentica sfruttando tre leve psicologiche fondamentali:

- **Saturazione Cognitiva:** L'invio in data 10 luglio 2026 avviene durante il picco operativo dello staff, impegnato nei preparativi per i Quarti di Finale a Kansas City, riducendo la capacità di analisi critica del target.
- **Autorevolezza Istituzionale:** L'impersonificazione di **Bank of America**, sponsor ufficiale, inquadra la richiesta come un'interazione business-as-usual attesa, minimizzando la percezione del rischio.
- **Leva della Perdita:** La prospettiva del congelamento dei budget pubblicitari agisce come un catalizzatore di ansia, forzando la vittima ad agire entro le 24 ore per proteggere gli interessi della holding.

2. Red Flags: Errori e Indicatori di Compromissione (IoC)

Nonostante l'accuratezza del pretesto, sono emersi errori strutturali che un team di sicurezza avrebbe potuto identificare facilmente:

- **Typosquatting:** Il dominio mittente bankofamerica-marketing.com è un'anomalia tecnica che per chi conosce il dominio originale potrebbe risultare debole
- **Disallineamento URL:** L'iperlink nel corpo del testo punta a un server esterno non certificato, indicatore diretto di un tentativo di *Credential Harvesting*.
- **Assenza di Firma Digitale:** La mancanza di protocolli di autenticazione crittografica (SPF/DKIM) rende l'e-mail soggetta a blocco automatico dai gateway di sicurezza aziendali.

Al fine di mitigare questo vettore di attacco, si raccomanda l'adozione di un sistema di autenticazione FIDO2/Passkey e l'implementazione di controlli DMARC rigorosi su tutti i domini corporate della holding

PARERE PERSONALE

Dal mio punto di vista, l'architettura di attacco qui delineata rappresenta al momento la strada più rapida per colpire un target di alto profilo. La capacità di orchestrare una campagna di phishing mirata, completa di dominio di spoofing e pagina di atterraggio, in un arco temporale di appena 24 ore, dimostra una bassa soglia di costo e una rapidità di esecuzione che la rendono estremamente difficile da contrastare con i metodi difensivi tradizionali. Ritengo che questa strategia sia, allo stato attuale, la più efficace nel breve periodo, specialmente se inserita in contesti di caos informativo globale — come il periodo dei Mondiali di Calcio (inclusa la risonanza mediatica attorno alla figura

di Messi). In momenti di grande fermento, la soglia di attenzione dei target di alto livello si abbassa drasticamente: la vittima è bombardata da comunicazioni, notifiche e richieste urgenti, rendendo il fattore umano l'anello debole più vulnerabile.

Integrazione dei Postulati di Cialdini (Analisi Psicologica)

- **Autorità:** L'email simula di provenire da un'istituzione finanziaria globale (Bank of America). Marcelo, gestendo la holding di una celebrità, è abituato a ricevere comunicazioni da banche e partner istituzionali; la naturale deferenza verso tali entità abbassa la sua guardia critica.
- **Urgenza:** La comunicazione utilizza un pretesto di "verifica account" o "transazione sospetta". Creando un limite temporale breve (es. "Il conto verrà limitato entro 24 ore"), l'attaccante spinge la vittima ad agire impulsivamente per evitare un danno reputazionale o operativo alla holding.
- **Consistenza/Coerenza:** Poiché Marcelo gestisce operazioni finanziarie complesse, riceve spesso richieste di conferma. La richiesta di phishing si inserisce perfettamente nel suo normale flusso di lavoro, rendendola percepibile come "coerente" con le sue mansioni quotidiane.

Maltego:

